TABDEELI KI REPORT

✓ Theek ho gaya

# Checkout par coupon do baar laga, aur koi bhi customer doosre customer ki invoice download kar sakta tha

PROJECT ShopFlow online store (demo) BRANCH `fix/checkout-coupon-invoice-access` COMMIT `a71c0d9`

TAREEKH 2026-10-29 TAYYAR KIYA Claude (AI coding agent) KIS KE KEHNE PAR Maria Lopez, QA lead

## 01 Khulasa

Release se pehle checkout aur order history ke pages test karte hue do ghaltiyan mili. Dono is branch par theek ho chuki hain.

Jab customer cart ka page refresh karta tha to coupon doosri dafa lag jata tha, is liye test run ke 1,240 orders kam charge hue (kul USD 3,180). Doosri ghalti: invoice download ka link kisi bhi order number ko qubool kar leta tha. Logged-in customer address bar mein number badal kar kisi aur ki invoice, us ke naam, pate aur saman samet, download kar sakta tha.

Ab coupon sirf ek dafa cart ke subtotal se nikalta hai aur order ke saath save hota hai, aur har invoice sirf signed-in customer ke apne orders se load hoti hai. Dono rules ke naye tests hain, aur ek insaan ne do alag customer accounts se haath se dobara jaanch ki.

EK NAZAR MEIN

**2**
**Masail mile**
- 1 intehai sangeen
- 1 sangeen

**3**
**Hal kiye**
2 mein se 2 masail ka hal

**5** / 7
**Kamyab jaanchein**
1 adhoori · 1 nahi chalayi

**2**
**Ijazat ki darkhwastein**
1 manzoor · 1 mehfooz rasta

**1 → 0**
**Scan ke sangeen nataij**
pehle → baad mein

## 02 Pehle kya masla tha

Har masla waise hi jaise mila, kuch badalne se pehle.

SANGEEN P1

### Cart refresh karne par coupon ka discount do baar lag jata tha

KAHAN `applyCoupon()` in `src/services/cart.ts` KIS NE PAKRA Test HAL F1 F3

**KYA NAZAR AAYA**

USD 50.00 ke cart par 10% coupon ke baad ek refresh karne se total USD 45.00 ki jagah USD 40.50 aa gaya.

**ASAL WAJAH**

`applyCoupon()` discount asal subtotal ke bajaye maujooda total se kaat raha tha, aur har cart refresh par dobara chalta tha. Kahin yeh darj nahi tha ke coupon pehle lag chuka hai.

**ASAR**

Staging test run mein 9,800 mein se 1,240 orders kam charge hue, kul USD 3,180. Production mein yeh aamdani ka nuqsan aur manual refunds ya dobara billing hoti.

**SABOOT**

> Test order SF-20261029-0417: subtotal 50.00, coupon SAVE10, charge 40.50.
> Cart log mein ek hi cart ke liye 4 seconds ke andar `applyCoupon` do baar chala.

INTEHAI SANGEEN P2

### Invoice download yeh check nahi karta tha ke order kis ka hai

KAHAN `GET /api/orders/:id/invoice` in `src/routes/orders.ts` KIS NE PAKRA Insaan HAL F2 F3

**KYA NAZAR AAYA**

Test customer A ke taur par sign in kar ke `/api/orders/1002/invoice` kholne se customer B ki invoice download ho gayi.

**ASAL WAJAH**

Route order ko `Order.findById(req.params.id)` se load karta tha aur sirf yeh dekhta tha ke koi signed in hai, yeh nahi ke order usi ka hai. Order numbers silsilewar hain, is liye aasani se andaaza lagaya ja sakta hai.

**ASAR**

Koi bhi customer doosron ke naam, pate, phone numbers aur khareedari parh sakta tha: personal data ka leak, jise kai mulkon mein report karna zaroori hota hai.

**SABOOT**

> Customer A (id 77) ki taraf se order 1002 (customer 81 ka) ki request par HTTP 200 aur PDF wapas aayi.

## 03 Kya theek kiya

Kya badla, yeh hal sahi kyun hai, aur code pehle aur baad mein.

### F1 Coupon sirf ek dafa, subtotal se nikalna

**KIS MASLE KA HAL** — P1 Cart refresh karne par coupon ka discount do baar lag jata tha

**KYA BADLA** — Discount ab `cart.subtotal` se nikalta hai, aur laga hua coupon cart par save hota hai. Wahi coupon dobara lagane se kuch nahi badalta. Database mein (cart_id, coupon_code) par unique index duplicate ko rokta hai.

**YEH SAHI KYUN HAI** — Total ab is par mabni nahi ke page kitni dafa load hua, aur do requests ek saath aayein to bhi database doosri copy qubool nahi karta.

**FILES** — `src/services/cart.ts` `migrations/20261029_add_cart_coupon_unique.ts` `tests/cart.coupon.test.ts`

**– PEHLE** TYPESCRIPT

```
  export function applyCoupon(cart: Cart, coupon: Coupon) {
-   cart.total = cart.total * (1 - coupon.percent / 100);
    return cart;
  }
```

**+ BAAD MEIN** TYPESCRIPT

```
  export function applyCoupon(cart: Cart, coupon: Coupon) {
+   if (cart.couponCode === coupon.code) return cart;
+   cart.couponCode = coupon.code;
+   cart.total = cart.subtotal * (1 - coupon.percent / 100);
    return cart;
  }
```

### F2 Invoice sirf customer ke apne orders se load karna

**KIS MASLE KA HAL** — P2 Invoice download yeh check nahi karta tha ke order kis ka hai

**KYA BADLA** — Route ab order ko order id aur signed-in customer ki id, dono se dhoondta hai, aur match na ho to 404 deta hai.

**YEH SAHI KYUN HAI** — Customer sirf apne orders tak pohanch sakta hai. 404 jawab yeh bhi nahi batata ke kisi aur ka order maujood hai ya nahi.

**FILES** — `src/routes/orders.ts` `tests/orders.invoice.test.ts`

**– PEHLE** TYPESCRIPT

```
  router.get('/orders/:id/invoice', requireLogin, async (req, res) => {
-   const order = await Order.findById(req.params.id);
    res.download(invoicePath(order));
  });
```

**+ BAAD MEIN** TYPESCRIPT

```
  router.get('/orders/:id/invoice', requireLogin, async (req, res) => {
+   const order = await Order.findOne({ _id: req.params.id, customerId: req.user.id });
+   if (!order) return res.sendStatus(404);
    res.download(invoicePath(order));
  });
```

F3 **Dono rules ke tests**

| | |
|---|---|
| KIS MASLE KA HAL | P1 Cart refresh karne par coupon ka discount do baar lag jata tha<br>P2 Invoice download yeh check nahi karta tha ke order kis ka hai |
| KYA BADLA | Naye tests: cart teen dafa refresh karne par bhi ek hi discount; customer A ko customer B ki invoice par 404 aur apni par 200. |
| YEH SAHI KYUN HAI | Dono tests purane code par fail hue aur naye par pass, is liye yahi ghalti wapas aaye to foran pakdi jayegi. |
| FILES | `tests/cart.coupon.test.ts` `tests/orders.invoice.test.ts` |

## 04 Jaanch

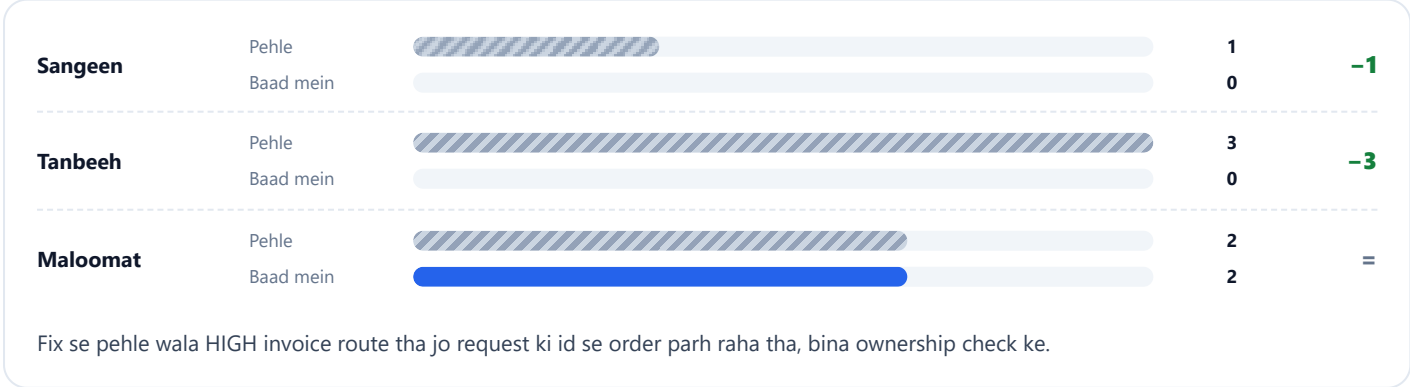
Tabdeeli ko kaise jaancha gaya: AI agent ne bhi aur insaanon ne bhi.

7 jaanchein: AI ne 3, insaanon ne 3, dono ne 1.

| JAANCH | KIS NE JAANCHA | NATEEJA | TAFSEEL |
|---|---|---|---|
| Automated tests (npm test) | AI | ✓ Kamyab | 214 tests, 0 failures; 2 naye tests fix se pehle fail hote the. |
| safe-ai-coding review scan (diff-check) | AI | ✓ Kamyab | Koi HIGH ya WARN baqi nahi; 2 INFO bahar jane wali calls ke, dono mutawaqqe. |
| Missing-symbol check | AI | ✓ Kamyab | Tabdeeli mein istemal har function, import aur route maujood hai. |
| Do customer accounts se manual test | Insaan | ✓ Kamyab | Customer A, customer B ki invoice nahi khol saka; dono apni apni khol sake. |
| Coupon ke saath checkout 5 dafa refresh | Insaan | ✓ Kamyab | USD 50.00 ke cart par SAVE10 ke saath total USD 45.00 hi raha. |
| Doosre developer ne code parha | AI + insaan | ◐ Adhoora | Approve kiya, ek note ke saath: baad mein `invoicePath` ka naam `invoiceFilePath` karein. |
| Checkout ka load test | Insaan | ○ Nahi chalaya | Release candidate ke liye plan hai. |

## 05 Scan: pehle aur baad mein

Fix se pehle aur baad mein tabdeeli ka red-flag scan.




Fix se pehle wala HIGH invoice route tha jo request ki id se order parh raha tha, bina ownership check ke.

## 06 Ijazatein

Woh khatarnak kaam jin ke liye agent ne ijazat maangi, aur jo nuqsan us ne bataya.

| KAAM | MUMKINA NUQSAN | FAISLA | KAB |
|---|---|---|---|
| Nayi migration local database par chalana | Unique index add hota hai; agar pehle se duplicate rows hon to fail ho jati hai | ✓ Manzoor | 2026-10-29 11:05 |
| Wahi migration shared staging database par chalana | Carts table kuch seconds ke liye lock hoti hai; doosre testers ko tabdeeli foran nazar aati hai | ↪ Mehfooz rasta | 2026-10-29 11:20 |

## 07 Badli gayi files

| FILE | SHAMIL | HAZF | HISSA |
|---|---|---|---|
| `src/services/cart.ts` | +6 | −2 | |
| `src/routes/orders.ts` | +3 | −1 | |
| `migrations/20261029_add_cart_coupon_unique.ts` | +14 | −0 | |
| `tests/cart.coupon.test.ts` | +38 | −0 | |
| `tests/orders.invoice.test.ts` | +31 | −0 | |
| **Kul** | **+92** | **−3** | |

## 08 Baqi khatre

Jo abhi poori tarah mehfooz nahi. Is tabdeeli par bharosa karne se pehle inhein parhein.

! Staging mein jo orders kam charge hue, data kahin aur copy hone se pehle unhein theek karna zaroori hai.

! Doosre download routes (receipts, shipping labels) bhi yahi tareeqa use karte hain aur abhi check nahi hue.

## 09 Agle qadam

1. Tay shuda khamosh waqt mein staging par migration chalayein.
2. Receipts aur shipping-label routes mein bhi yahi ownership check dekhein.
3. Release se pehle checkout ka load test chalayein.

Yeh report safe-ai-coding 2.1.0 ne 2026-10-29 13:00 UTC+05:00 par banayi · Sami Hussain, x8code.com · github.com/sami-hussain-dev/safe-ai-coding

*Scan aur test khatra kam karte hain magar yeh saabit nahi karte ke code mehfooz hai; har tabdeeli ko ek insaan ko zaroor dekhna chahiye.*